



Module 1 (HTB Certified Junior Cybersecurity Associate)

@manishburdak45

https://www.linkedin.com/in/manish-burdak-718067380?utm_source=share_via&utm_content=profile&utm_medium=member_android

Structure of Information Security (InfoSec)

Structure of InfoSec

Processes

- Policies, procedures, and guidelines for managing security
- Defines how security tasks are performed
- Examples: incident response plans, access control policies
- **Coordination ensures consistency**



Technology

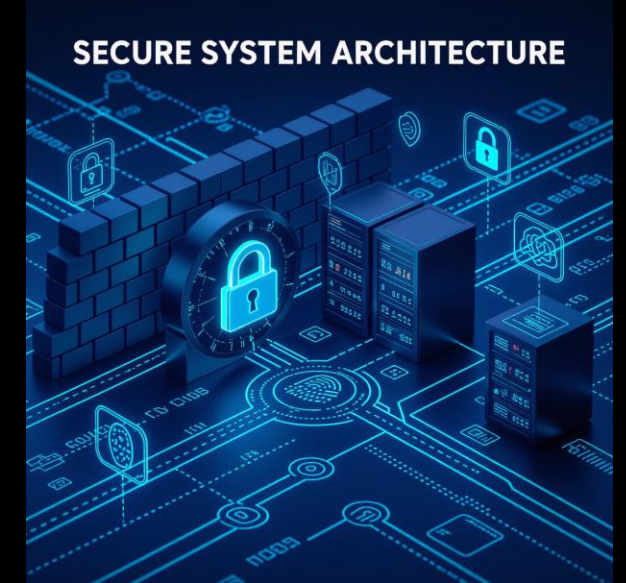
- Users, employees, and security professionals
- Must follow security policies and best practices
- **Human error is a leading cause of breaches**
- Training and awareness are critical



People

- Tools and systems protecting information
- Includes hardware and software solutions
- Examples: firewalls, antivirus, IDS/IPS, encryption
- **Technology alone cannot secure systems**

Critical Insight: Security fails if any pillar is weak. All three must work together to create a strong cybersecurity foundation.



Key Points of InfoSec Structure

InfoSec protects data from unauthorized access and attacks through a combination of people, processes, and technology. Security is not only about tools but also about policies and human behavior. Proper coordination between these three components creates a strong security framework that is resilient and comprehensive.

Real-World Example Why All Three Matter

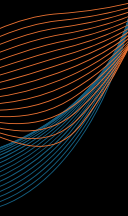
A company protects its data by implementing all three elements: **People** — training employees about phishing attacks and security awareness; **Processes** — creating security policies, procedures, and incident response plans; **Technology** — deploying firewalls, intrusion detection systems, encryption, and access controls. Each element reinforces the others.

Security fails if any of the three elements are weak. Human error is one of the most common security risks, making people training essential. Without strong processes, technology tools lack direction. Without technology, processes and people cannot scale effectively. This **three-pillar structure forms the foundation of modern cybersecurity frameworks** and must be balanced for true protection.

Roles in Information Security

Understanding key security roles and their relationship to penetration testing helps contextualize the importance of this work within an organization.

Role	Description	Relevance to Penetration Testing
Chief Information Security Officer (CISO)	Oversees the entire information security program	Sets overall security strategy that pen testers will evaluate
Security Architect	Designs secure systems and networks	Creates the systems that pen testers will attempt to breach
Penetration Tester	Identifies vulnerabilities through simulated attacks	Actively looks for and exploits vulnerabilities within a system, legally and ethically. This is likely your target role.
Incident Response Specialist	Manages and responds to security incidents	Often works in tandem with pen testers by responding to their attacks, and sharing/collaborating with them afterwards to discuss lessons learned.
Security Analyst	Monitors systems for threats and analyzes security data	May use pen test results to improve monitoring
Compliance Specialist	Ensures adherence to security standards and regulations	Pen test reports often support compliance efforts



Principles of Information Security

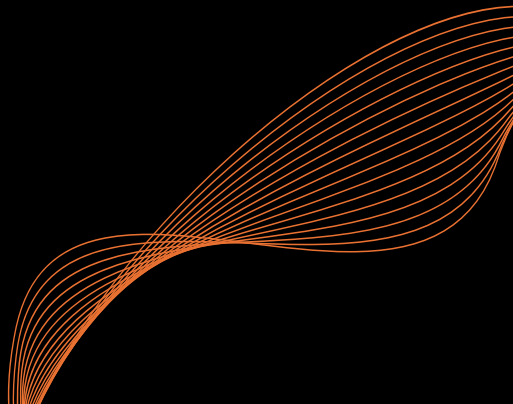
Information security operates under a set of fundamental guiding principles that form the bedrock of effective protection and management of critical data assets. These principles provide the rules, guidelines, and framework that shape organizational policies, control measures, and security practices.

Why These Principles Matter:

Broad Applicability — These principles are relevant not only to InfoSec professionals but to anyone interacting with information systems. They influence system design, operational practices, incident response, and the legal and ethical standards governing IT use.

Theoretical Foundation — Understanding these principles is crucial for making informed decisions about protecting information assets. They provide the structure needed to assess the effectiveness of current security measures and guide the development of new ones.

Practical Implementation — In the sections ahead, we will explore each principle in depth—examining their significance, real-world applications, and relevance to various InfoSec roles and responsibilities.





InfoSec Roles and Responsibilities

- **Confidentiality**
 - Ensures information is accessible only to authorized individuals. Protects against unauthorized disclosure through encryption and access controls.
- **Integrity**
 - Maintains accuracy and completeness of data throughout its lifecycle. Protects against unauthorized modification using hashing and digital signatures.
- **Availability**
 - Guarantees information is accessible to authorized users when needed. Protects against access disruption through redundancy and disaster recovery planning.
- **Non-repudiation**
 - Prevents parties from denying the authenticity of their digital signatures or messages. Critical for e-commerce and legal contexts, implemented via audit logs.
- **Authentication**
 - Verifies the identity of users, processes, or devices before granting access. Implemented through passwords, biometrics, and multi-factor authentication.
- **Privacy**
 - Focuses on proper handling of sensitive personal information and regulatory compliance. Implemented through data minimization and consent management.

Information Security: Processes and Purposes

Key Processes in Information Security

- **Risk Assessment** — Identifies and evaluates potential threats and vulnerabilities; determines impact of breaches; prioritizes security efforts
- **Security Planning** — Develops strategies to address identified risks; creates policies and procedures; allocates resources
- **Implementation of Security Controls** — Deploys technical solutions and enforces policies; includes preventive and detective controls
- **Monitoring and Detection** — Continuously watches for security events using SIEM systems and intrusion detection; identifies incidents quickly
- **Incident Response** — Reacts to detected incidents following established procedures; contains and mitigates threats
- **Disaster Recovery** — Restores systems and data after major incidents; implements backup and redundancy measures
- **Continuous Improvement** — Reviews incidents and near-misses; updates measures based on new threats; conducts regular assessments

Primary Purposes of Information Security

- **Protecting Sensitive Data** — Safeguards confidential information (personal data, financial records, trade secrets); prevents breaches and financial loss
- **Ensuring Business Continuity** — Maintains availability of critical systems; enables operations during security incidents or disasters
- **Maintaining Regulatory Compliance** — Ensures adherence to data protection laws and industry standards; avoids legal penalties
- **Preserving Brand Reputation** — Protects against reputational damage; demonstrates commitment to stakeholder interests
- **Safeguarding Intellectual Property** — Protects valuable ideas and inventions from theft; maintains competitive advantage
- **Enabling Secure Digital Transformation** — Allows safe adoption of new technologies; supports innovation while managing security risks

Firewalls

Act as barriers between trusted internal networks and untrusted external networks, filtering traffic based on predetermined security rules.

Real-World Analogy:
Locked mailbag = Firewall (separating trusted mail from threats)

Network Security

Intrusion Detection and Prevention Systems (IDS/IPS)

Monitor network traffic for suspicious activities and take automated actions to detect or block potential threats.

Real-World Analogy: Vigilant eye = IDS/IPS (watching for suspicious packages)

Additional security layer:
Access Control Mechanisms — Include authentication and authorization protocols to ensure only legitimate users can access network resources.

Virtual Private Networks (VPNs)

Provide secure, encrypted connections over public networks, ensuring data privacy and integrity during transmission. Commonly used by employees to connect to internal network resources.

Real-World Analogy: Secure courier services = VPNs (extra protection for confidential documents)

Data protection: **Encryption Technologies** — Protect sensitive data both in transit and at rest, rendering it unreadable to unauthorized parties. **Tamper-evident seals** = Encryption (keeping contents unreadable to unauthorized parties)



Responsibility

- **IT Department & Network Security Team**
- The **Network Security Manager** (reporting to the CISO) leads the team responsible for designing, implementing, and maintaining security infrastructure. Core responsibilities include configuring security devices, developing security policies, monitoring network traffic for threats, and responding to incidents.
-
- **Security Testing & Assessment**
- **Penetration testers and ethical hackers** simulate real-world attacks to identify vulnerabilities and weaknesses. Larger organizations maintain internal security teams, while smaller companies typically engage external consultants or managed security service providers for regular assessments.
-
- **Stakeholder Collaboration**
- **CISO** sets overall security strategy; **CIO/IT Director** allocate resources; **Network Administrators & Security Analysts** handle day-to-day operations; **Compliance Officers** ensure regulatory alignment; **Risk Management Teams** prioritize investments based on business impact. Effective network security requires coordination across all these roles.

- Application Security
- Application security is a critical component of information security and is often a significant factor in breaches if not properly implemented. It focuses on protecting software applications from external threats throughout their entire lifecycle. This encompasses a wide range of practices, tools, and methodologies designed to identify, prevent, and mitigate security vulnerabilities in application code and its associated infrastructure. The primary goal is to ensure that applications are developed, deployed, and maintained in a manner that preserves the confidentiality, integrity, and availability (CIA Triad) of the data they process and the systems they interact with. This is particularly crucial in today's interconnected digital landscape, where applications often handle sensitive information and are exposed to a myriad of potential threats from malicious actors.
- Application Security begins at the earliest stages of the software development lifecycle and continues through to deployment and ongoing maintenance. It involves a combination of secure coding practices, rigorous testing procedures, and the implementation of various security controls. Developers play a crucial role in this process by writing code that adheres to security best practices and is resistant to common vulnerabilities such as SQL injection, cross-site scripting (XSS), and buffer overflows.
- Imagine you're designing a house, and the goal is to make sure it's safe from burglars (hackers) and natural disasters (threats). Below is a simple pseudo-code for how Application Security can work, broken down step by step:

Application Security Overview

Application security protects software systems from threats across the **entire development lifecycle**—from design and coding to deployment and ongoing maintenance. Its goal is to safeguard the **Confidentiality, Integrity, and Availability (CIA Triad)** of the data and systems applications rely on.

- **Lifecycle Protection** — Security begins during development and continues through testing, deployment, and updates.
- **Secure Coding Practices** — Developers prevent common vulnerabilities such as **SQL injection**, **cross-site scripting (XSS)**, and **buffer overflows**.
- **Security Testing & Controls** — Tools and reviews identify weaknesses early and ensure strong protection before release.
- **Real-World Analogy** — Building secure software is like designing a **house with locks, alarms, and strong foundations** to stop attackers before they enter.

Understanding Application Security Through a House Analogy

Inspect the House (Test for Vulnerabilities)

Start Building the House (Develop the App)

Keep the House Safe Over Time (Monitoring)

Building an application is like constructing a house. **Authentication** works like door locks—only the right users should enter. Strong, well-written **secure code** acts as sturdy walls that prevent attackers from exploiting weaknesses. **Data encryption** is like a waterproof roof, protecting sensitive information while it moves across networks.

After building, the system must be tested. **Penetration testing** checks whether attackers can bypass security—similar to testing door locks. Developers search the code for **bugs and weak spots**, just like inspecting walls for cracks. Security testing ensures **data protection mechanisms** hold up under pressure.

Security does not stop after launch. **Monitoring tools** act like security cameras watching for threats. Regular **updates and patches** repair newly discovered vulnerabilities, similar to fixing cracks or replacing broken locks to keep the house safe.

CYBERSECURITY FUNDAMENTALS

Application Security • OpSec • Cloud Security

Build Secure. Test Thoroughly. Monitor Always.

Real-world analogies to make security concepts stick



CIA TRIAD INSIDE

Confidentiality • Integrity • Availability

APPLICATION SECURITY



Think of your app like a **HOUSE** — you need locks, strong walls, and a waterproof roof to keep it safe!



LOCKS ON DOORS

Authentication

Only right people get in — just like good locks keep strangers out of your house.



STRONG WALLS

Secure Code

App code must be solid & free of weaknesses hackers can exploit.



WATERPROOF ROOF

Data Encryption

Encrypt data so no one can read or steal it in transit — like a leakproof roof.

SECURITY BY DESIGN

💡 **Security is NOT an afterthought — it's built in from Day 1, just like designing a house with secure locks BEFORE construction begins.**

Threat Modeling

Imagine all ways someone could break in — identify risks early during planning stage.

Secure Code Review

Check code for weak spots after writing — like inspecting a foundation for cracks.

Servers & Databases

Like the land your house sits on — if insecure, the whole system is at risk.

Auth & Authorization

High-quality locks. Auth = who you are. Authorization = which rooms you can enter.

TEST • MONITOR • UPDATE

01

Inspect the House

Penetration Testing

- Test if locks are working
- Look for cracks in walls
- Test roof with water

02

Security Cameras

Ongoing Monitoring

- Watch for intruders 24/7
- Detect new threats in real time
- Audit logs continuously

03

Fix & Upgrade

Patch Management

- Replace broken locks (patches)
- Repair cracks (bug fixes)
- Update security systems

⚠ When `test_if_locks_are_working()` fails — hackers find that open door and exploit it. Never skip testing!

APPSEC RESPONSIBILITY



App Developers

Write secure code; implement security features on the front lines.



Security Architects

Design overall security structure of apps and infrastructure.



IT Operations

Maintain security of the production environment where apps run.



AppSec Manager / CISO

Set policies, ensure compliance, oversee all security measures.



Penetration Testers

Simulate attacks using static/dynamic analysis, fuzzing, manual reviews.

OPERATIONAL SECURITY (OpSec)



Analogy: You're hosting a birthday party. OpSec = your plan to keep valuables (console, jewelry) safe while everyone enjoys the event.

1

Asset Identification

Which items are most precious? → Identify your critical information assets.

2

Threat Identification

What could go wrong? Console knocked over? Guest wanders in? → Analyze threats.

3

Vulnerability Check

Lock valuables, restrict rooms → Passwords, security badges, cameras.

4

Access Control

Only trusted friend gets key to your room → Right people, right permissions.

5

Monitoring

Stay alert during the party. Adjust if guests go where they shouldn't → Adapt to new threats.

OpSec — KEY COMPONENTS

Access Control

Multi-factor authentication + authorization systems. Regular audits — revoke permissions when employees change roles or leave.

Asset Management

Up-to-date inventory of ALL assets: hardware, software, data. Know what exists, where it is, and its importance.

Change Management

Changes made in a controlled way with proper testing & approval. Prevents new vulnerabilities being introduced during updates.

Security Awareness Training

Educate ALL employees: phishing attacks, strong passwords, handling sensitive info. Everyone is a security stakeholder.

CLOUD SECURITY



Analogy: A HIGH-TECH SHARED STORAGE FACILITY. You store valuables there instead of home. The facility provides guards & cameras — YOU must lock your own unit.

THREATS



Data Breach

Someone picks your lock → unauthorized access to your data



Insecure APIs

Flawed access system → hackers exploit it to get in



Misconfiguration

Forgot to lock your unit → data exposed to public



Account Hijacking

Stolen access card → attacker controls your account

DEFENSES



Data Protection

Encrypt at rest & in transit — strong lock + safe inside unit



IAM

Personalized key only you know — authorized access only



Network Security

Firewalls + VPNs — secure hallways & monitored entrances



Compliance & Governance

Follow rules & laws about data handling — no illegal items

SHARED RESPONSIBILITY MODEL

Cloud Provider

Facility Management

- ✓ Secure building (infrastructure)
- ✓ Surveillance cameras operational
- ✓ Security guards on duty
- ✓ Overall cloud environment safety

You / Admin

Your Storage Unit

- ✓ Lock your unit properly
- ✓ Keep your access key safe
- ✓ Strong passwords for accounts
- ✓ Manage user access rights

Security Team

Head of Security

- ✓ Develop security strategies
- ✓ Conduct risk assessments
- ✓ Coordinate technical measures
- ✓ Human + technical elements

THE CIA TRIAD

The foundation of every security decision

C

CONFIDENTIALITY

Ensuring only authorized people can access information.

 *Lock analogy: Only the right guest gets the key to your room.*

Real use: Encryption, passwords, access control

I

INTEGRITY

Ensuring data is accurate and has not been tampered with.

 *Wall analogy: Walls stay solid — no cracks let attackers alter your structure.*

Real use: Checksums, digital signatures, audit trails

A

AVAILABILITY

Ensuring systems and data are accessible when needed.

 *Power analogy: Lights and water always work when you need them.*

Real use: Backups, redundancy, disaster recovery

KEY TAKEAWAYS

01 Application Security = Building a secure house. Locks (auth), walls (code), roof (encryption) — from day one.

02 Security by Design means you plan security IN — not bolt it on after the app is already built.

03 OpSec = Birthday party plan. Identify assets → threats → vulnerabilities → control access → monitor.

04 Cloud Security = Shared storage facility. Provider secures building; YOU must lock your own unit.

05 CIA Triad: Confidentiality + Integrity + Availability — the three pillars every security decision must protect.

INFORMATION SECURITY

Physical · Mobile · IoT · Cyber Threats

Physical Security

Mobile Security

IoT Security

DDoS

Ransomware

Manish Burdak

PHYSICAL SECURITY

Protecting hardware, facilities & physical access to data

Physical security refers to protection of actual hardware and facilities that store and process data — including computers, servers, network equipment, and printed documents. It prevents unauthorized physical access that could lead to data breaches or damage.

Defense in Depth — Layered Approach:

DETER

Fencing, lighting, signage

DETECT

Cameras, alarms, sensors

DELAY

Reinforced doors, locks

RESPOND

Security guards, police

Why It Matters:

- Protects valuable assets & expensive equipment
- Ensures safety of employees & visitors
- Maintains operational continuity
- Required for regulatory compliance

PHYSICAL VULNERABILITIES

Common weaknesses that Red Teamers / Penetration Testers look for:

Unsecured Access Points

Doors/windows left unlocked or easily bypassed

Weak Locks

Outdated or low-quality locks, easily picked

Inadequate Perimeter

No fencing, barriers, or surveillance around facility

Poor Key Management

Improper handling of keys or access cards

Insufficient Lighting

Dark areas that conceal intruder activity

Exposed IT Infrastructure

Servers/network devices accessible to unauthorized persons

Weak Visitor Management

No proper protocols to identify or escort visitors

Unattended Workstations

Unlocked computers left in public/shared spaces

MOBILE SECURITY

Protecting mobile devices, data, and the networks they connect to



Device Security

- Passcodes & PINs
- Biometric authentication
- Remote wipe capabilities



Data Security

- End-to-end encryption
- Secure backups
- Data loss prevention



Network Security

- VPN for public Wi-Fi
- Secure protocols (HTTPS)
- Avoid unsecured networks



App Security

- App vetting before install
- Permission management
- Secure development practices

IoT SECURITY

Internet of Things — securing the network of everyday connected devices

IoT = Smart thermostats, cameras, wearables, industrial sensors, connected cars — all internet-connected devices. If a smart thermostat is hacked, attackers can gain access to your entire home network, including personal files and sensitive data.

Who is Responsible?

Device Manufacturers

Design with security-first principles, minimize unnecessary features, provide timely updates.

Network Administrators

Secure networks, implement network segmentation, deploy intrusion detection systems.

Application Developers

Implement proper authentication, protect data through encryption and secure coding.

DDoS ATTACK

Distributed Denial of Service — overwhelming a target with flood traffic

3 Main Components:

1. The Attacker

Person/group coordinating the attack, targeting a specific victim to disrupt services.

2. The Botnet

Network of compromised devices (PCs, IoT devices) hijacked without owners' knowledge — sends mass requests simultaneously.

3. The Victim

Targeted server or network overwhelmed by traffic — legitimate users cannot access the service.

⚠ Real Case — Dyn Attack 2016

Mirai botnet (compromised IoT devices) attacked Dyn DNS — Twitter, Netflix, Reddit went down for hours across USA & Europe.

RANSOMWARE

Malware that encrypts your files and demands payment for decryption

How a Ransomware Attack Unfolds:

Step 1: Entry

Phishing email with malicious link/attachment tricks user into installing malware.

Step 2: Encrypt

Ransomware encrypts files (documents, photos, databases) using complex algorithms — data becomes unreadable.

Step 3: Demand

Ransom note displayed with payment instructions (usually Bitcoin) and a deadline.

Step 4: Risk

No guarantee of decryption after payment. Paying may mark victim for future attacks.

⚠️ WannaCry Attack — May 2017

200,000+ computers in 150+ countries. UK NHS hospitals locked out of patient records — surgeries canceled. Exploited unpatched Windows vulnerability. Caused billions in damages worldwide.

IMPACT & KEY TAKEAWAYS



Financial Loss

Downtime, ransom, recovery costs can run into billions



Operational Shutdown

Critical services like healthcare can be completely halted



Reputation Damage

Customer trust erodes, long-term revenue decline follows



Data Loss

Permanent loss of important data if backups are unavailable



Cycle of Crime

Paying ransoms encourages attackers and invites future attacks



Ripple Effects

Impact spreads beyond direct victim to all dependent users/services

@manishburdak45



CYBERSECURITY

THREATS & HUMAN VULNERABILITIES

Social Engineering • Insider Threats • APTs

SOCIAL ENGINEERING

Manipulating human
trust to gain
unauthorized access



Real-Life Example

A stranger in uniform approaches you at a train station. Appearing trustworthy, they trick you into handing over your luggage — exactly how cybercriminals manipulate trust.

IMPACT



Data Breaches

Millions of records stolen



Financial Loss

Fraud and monetary damage



Reputation

Eroded customer trust



Operations

System downtime & disruption

The human element is the most exploited vulnerability in cybersecurity.

5 CORE SOCIAL ENGINEERING TECHNIQUES

How attackers exploit human behavior

01



Phishing

Fake emails/messages mimicking trusted sources to steal credentials.

📌 A fake bank email asks you to 'verify' your login — the link captures your password.

02



Pretexting

Creating a fabricated scenario to extract sensitive info.

📌 Fake IT support calls asking for your login to 'fix a computer issue'.

03



Baiting

Luring victims with enticing promises into a trap.

📌 USB drive labeled 'Employee Salaries 2023' left in parking lot — installs malware when plugged in.

04



Tailgating

Physically following authorized personnel into secure areas.

📌 Person with large box asks you to hold the secure door — they enter without credentials.

05



Quid Pro Quo

Offering a benefit in exchange for information or access.

📌 Free software upgrade offered in exchange for login credentials.

INSIDER THREATS

The danger from within your trusted circle

The Café Analogy

You've secured your café against external thieves — cameras, alarms, locks. But your trusted barista secretly copies your secret recipe and sells it to a rival. This is the insider threat: danger from inside your own circle.

Insider Threat Kill Chain

1. Motivation — grievance, greed, coercion
2. Planning — assess access & identify targets
3. Preparation — gather tools, copy data
4. Execution — theft, sabotage, sharing data
5. Concealment — delete logs, cover tracks

3 TYPES



Malicious Insider

Intentional harm — steal secrets, commit fraud, sabotage systems for personal gain or revenge.



Negligent Insider

Unintentional harm — sends confidential data to wrong email, falls for phishing scams.



Compromised Insider

External attacker steals credentials via hacking or social engineering, operates as insider.

 Insiders know WHERE valuable data is, making detection exceptionally difficult.

ADVANCED PERSISTENT THREATS (APTs)

Long-term, stealthy attacks by well-funded, often state-sponsored groups

Museum Heist Analogy:

Elite thieves don't smash and grab — they study blueprints, befriend staff, infiltrate as employees, and slowly steal priceless artifacts one by one. APTs work the same way: patient, stealthy, and devastating.

1



Reconnais- sance

Study blueprints & security protocols

2



Infiltration

Spear-phishing or exploiting vulnerabilities

3



Foothold

Install backdoors & malware

4



Lateral Move

Escalate privileges, access systems

5



Exfiltration

Stealthily transfer data out

6



Persistence

Maintain access, multiple backdoors

REAL CASE: SolarWinds Attack (2020)

State-sponsored attackers injected malicious code into a routine SolarWinds software update. When 18,000+ clients (including U.S. government agencies) installed the update, they unknowingly let attackers spy on them for months — undetected.

IMPACT & CONSEQUENCES

What's at stake across all three threat categories

Social Engineering

- ▶ Credential theft
- ▶ Account takeover
- ▶ Financial fraud
- ▶ Mass data breaches affecting millions
- ▶ Bypass all tech defenses

Insider Threats

- ▶ IP theft & trade secrets lost
- ▶ Competitive edge destroyed
- ▶ Employee morale collapse
- ▶ Regulatory fines (GDPR, HIPAA)
- ▶ Years of legal battles

APTs

- ▶ National security compromised
- ▶ Power grids & infrastructure at risk
- ▶ Economic espionage
- ▶ Political power shifts
- ▶ Months undetected in systems

KEY TAKEAWAYS

Defend Against Human-Targeted Attacks

Security Awareness Training

Regular training helps employees recognize phishing, pretexting, and social engineering in real time.

Zero Trust Architecture

Never assume trust — verify every user, device, and action even inside the network.

Monitor Insider Activity

Behavioral analytics and access logs help detect anomalies before damage is done.

Incident Response Plan

A practiced response plan minimizes damage when breaches occur — time is critical.

Patch & Update Regularly

APTs exploit known vulnerabilities. The SolarWinds attack showed even updates can be weaponized — verify supply chains.

Compliance & Governance

GDPR, HIPAA, and PCI DSS frameworks aren't just legal requirements — they enforce good security hygiene.

"The weakest link in any security system is the human element. Awareness is your strongest defense."



THREAT ACTORS

& CYBERSECURITY TEAMS

Threat Actors

Red Team

Blue Team

Purple Team

CISO

Pen Testers

SOC

Bug Bounty

Complete Study Notes — Basic to Advanced

01 WHAT IS A THREAT ACTOR?

The adversaries in the cyber world

Definition

A Threat Actor is an individual or organized group that carries out cyberattacks to breach systems, steal data, or cause disruption — for malicious purposes.

Bank Heist Analogy

Scout

Surveys the bank layout — like a cyber Reconnaissance Specialist using OSINT tools

Lockpicker

Bypasses locks — like a hacker using malware, rootkits & custom scripts

Getaway Driver

Plans escape — like an Exfiltration Specialist using VPNs & encryption

Leader

Coordinates the heist — the Team Leader setting strategy & objectives

TWO FORMS

Team (Organized Group)



Expert Programmers

Custom malware & exploits



Network Specialists

Navigate & probe infrastructure



Social Engineers

Psychological manipulation



Data Analysts

Process & extract stolen intel



Team Leaders

Coordinate & set strategy



Lone Wolf (Individual)

Operates autonomously. Motivated by personal interest, financial gain, or ideology. Ranges from simple phishing to sophisticated malware. Harder to detect — no team footprint.

02 OBJECTIVES & TACTICS

Why they attack and how they stay hidden

5 CORE MOTIVATIONS



Financial Gain

Theft via fraud, ransomware, dark web data sales



Espionage

Stealing govt/corporate secrets for strategic advantage



Disruption

Shutting down services, deleting data, spreading misinformation



Ideology

Hacktivism — promoting political, religious or social causes



Revenge

Retaliation attacks against organizations for perceived wrongs



"Low and Slow" — How They Avoid Detection

✓ Avoid Noisy Methods

No brute-force attacks — they trigger alarms. Instead: targeted, precise entry.

✓ Encrypted Channels

VPNs, Tor, and encrypted comms to hide their tracks during exfiltration.

✓ Use Stealth Malware

Custom malware designed to evade antivirus — not off-the-shelf tools.

✓ Patience

The "low and slow" approach — infiltrate quietly over weeks or months.

RED TEAM — The Ethical Attackers

Simulate real-world attacks to expose weaknesses — before real enemies do



Castle Analogy

A king hires expert warriors to dress as enemies and attack his own castle — not to destroy it, but to find hidden weak points before real invaders do. In cybersecurity, that's the Red Team.



How They Operate



Reconnaissance

Gather OSINT, study employees & infrastructure



Phishing Emails

Send convincing fake emails to trick staff



System Hacking

Exploit software bugs & network vulnerabilities



Physical Breach

Attempt unauthorized entry to secure areas



Full Report

Document findings → present to CISO for fixes

KEY OBJECTIVES



Test Human Factors

How susceptible are employees to social engineering & phishing?



Physical Security

Evaluate access controls, surveillance, and on-site barriers.



Realistic Attack Scenarios

Mirror advanced adversary tactics — multi-vector, sophisticated.



Improve IR Procedures

Enable faster, smarter incident response when real attacks occur.



Guide Security Investment

Findings show exactly WHERE to spend on defenses.



Engagements last weeks to months — covert & comprehensive

04 BLUE TEAM — The Defenders

The frontline defense — protecting digital assets 24/7

TEAM COMPOSITION



Security Analysts

Monitor networks & systems 24/7. First to spot anomalies — the watchtower guards.



Incident Responders

Digital first-responders. Contain & neutralize threats the moment a breach occurs.



Threat Hunters

Proactively hunt hidden threats BEFORE they're triggered. Digital detectives.



Security Engineers

Architects of digital fortifications — build, implement & maintain all defenses.

4 CORE OBJECTIVES



Continuous Monitoring

SIEM, IDS, EDR tools — detect threats in real-time around the clock.



Security Controls

Firewalls, access controls, patch management, and encryption protocols.



Incident Response

Investigate → Contain → Eradicate → Recover → Learn from every breach.



Collaboration & Training

Security-conscious culture — train all employees, stay ahead of threats.

PURPLE TEAM — Red + Blue United

Collaboration between attackers & defenders for continuous improvement



Medieval Kingdom Analogy:

Knights (Blue) defend the castle. Warriors (Red) simulate enemy attacks. When BOTH join forces — sharing attack insights and defense strategies together — that combined power is the Purple Team.



RED TEAM

Pen Testers
Ethical Hackers

+



BLUE TEAM

Incident Responders
Security Analysts

=



PURPLE TEAM

United Force
Continuous Loop

4 OBJECTIVES OF PURPLE TEAMING



Joint Testing

Red attacks while Blue defends — live, real-time collaboration exercises.



Knowledge Sharing

Red explains exploits; Blue explains detection — both get sharper.



Continuous Adaptation

Joint monitoring of evolving threats ensures strategies stay current.



Faster Incident Response

Regular collaboration = coordinated, faster response to real incidents.

CISO — Chief Information Security Officer

The guardian of the organization's entire digital kingdom



City Protector Analogy

Citizens = Employees | Buildings = Technologies | Treasures = Data
The CISO is the city's chief protector — anticipating threats, coordinating defense, and keeping everything running safely.



Key Functions



Develop Security Strategy

Design programs & policies to protect all digital assets



Manage Risk

Identify vulnerabilities, determine mitigation & acceptable risk



Oversee Incident Response

Lead the team during breaches — minimize damage fast



Enforce Security Policies

Set standards, controls & manage security technologies



Collaborate with Executives

Align security with business goals & risk tolerance

A DAY IN THE LIFE OF A CISO



Morning

Review overnight security reports & incidents. Assess if immediate action needed.



Mid-Morning

Meet with executives — align security strategy with new product launches or markets.



Midday

Oversee risk assessments — team identifies vulnerabilities in systems & network.



Afternoon

If breach: shift to incident response. Guide team to isolate & neutralize threat.



Late PM

Research new cyber threats, new tech, or conduct team training sessions.

PENETRATION TESTER (Ethical Hacker)

Acts like a malicious hacker — but to protect, not to harm



Locksmith Analogy:

Like a locksmith hired to pick your locks, enter your home & find hiding spots — then give you a report on weak points (bad locks, unsealed windows) with recommendations to fix them. The Pen Tester does exactly this for your digital 'home'.

KEY SKILLS



Technical Expertise

OS, programming, network protocols, common vulnerabilities



Analytical Thinking

Methodically test systems and interpret results precisely



Outside-the-Box

Approach problems in novel, unconventional, creative ways



Communication

Write clear reports — explain complex findings to non-tech teams

FUNCTIONS & IMPACT



Ethical Hacking

Simulate attacks on systems, networks & apps



Identify Vulnerabilities

Uncover weaknesses before real attackers find them



Assess Risk

Prioritize fixes by potential damage impact



Detailed Reporting

Present findings to management + recommend solutions



Security Awareness

Educate staff on phishing, social engineering vectors

Reports to: CISO | Works with: Sysadmins, Devs, Network Engineers

SECURITY OPERATIONS CENTER (SOC)

The command center — monitoring, detecting & responding to threats 24/7



Watchtower Analogy:

The SOC is the vigilant watchtower at the heart of a castle. Analysts = guards scanning the horizon. Alarms = SIEM alerts. SOC Manager = commanding officer directing all responses. The walls never sleep.



SOC Analyst Tiers

Tier 1 — Alert Triage

Handle initial alerts & perform basic threat analysis. First responders to notifications.

Tier 2 — Deep Investigation

Manage complex incidents, deeper investigations & mentor Tier 1 analysts.

Tier 3 — Advanced Response

Incident Responders & Threat Analysts — tackle the most critical security issues.

Also in the SOC:

SOC Manager — coordinates & ensures procedures are followed

Threat Hunters — proactively find hidden threats

Security Engineers — maintain SOC's tech infrastructure

SOC OBJECTIVES



Detect Threats Swiftly

Early identification is critical — every second counts when an attack begins.



Rapid Incident Response

Quick containment reduces the blast radius of any security breach.



Minimize Data Breaches

Proactive hunting finds intrusions before they escalate to full breaches.



Business Continuity

Efficient incident management means minimal disruption to operations.



Enhance Security Posture

SOC metrics & insights continuously improve the overall defense strategy.

SOC operates 24/7/365 — it never sleeps

09 BUG BOUNTY HUNTER

Independent cybersecurity researchers paid to find vulnerabilities — ethically

Bug Bounty Program

Organizations create structured programs inviting ethical hackers to find vulnerabilities in their apps, websites, or infrastructure. Researchers are rewarded with MONEY and RECOGNITION for valid reports.

Rewards scale by severity:
Critical bug = Premium payout
Low-severity bug = Smaller reward

Program Structure

Scope Definition

Which assets are eligible — websites, APIs, apps, infrastructure

Rules of Engagement

What's allowed and what's off-limits during testing

Reward Structure

Tiered payouts based on vulnerability severity & impact

 Private (invite only) |  Public (open to all)

FOR ORGANIZATIONS

Find Hidden Bugs

External experts spot what internal teams miss

Cost-Effective

Pay only for valid finds — no full-time hiring cost

Responsible Disclosure

Legal, structured channel for reporting vulnerabilities

Stronger Security

Continuously improve posture before attackers exploit gaps

Famous Platforms

HackerOne — the world's largest bug bounty platform
Bugcrowd — connects organizations with global hackers
Intigriti — Europe's leading bug bounty platform
Direct Programs — Google, Microsoft, Apple, Meta all run their own

FOR HUNTERS

Skill Growth

Real-world systems = best practice ground

Earn Money

Substantial rewards for critical finds

Recognition

Build reputation in global security community

Contribute

Make the internet safer for everyone

THE COMPLETE PICTURE

How all roles & teams connect in the cybersecurity ecosystem



Threat Actor

The Enemy

Attacks for money, espionage, disruption, ideology or revenge



Red Team

Ethical Attackers

Simulate real attacks to find weaknesses before enemies do



Blue Team

The Defenders

Monitor, detect, respond & protect digital assets 24/7



Purple Team

United Force

Red + Blue collaborate — continuous improvement loop



CISO

The Commander

Senior executive overseeing entire security strategy & risk



Pen Tester

Ethical Hacker

Finds vulnerabilities by acting as a simulated attacker



SOC

Command Center

24/7 monitoring hub — detect, analyze & respond to threats



Bug Bounty

Independent Hunter

Paid researchers who find & report vulnerabilities ethically

"In cybersecurity, knowing how to attack is what makes you great at defense. Master both — and you become the Purple Team."

THANK YOU

Manish Burdak

github.com/manishburdak45

Information Security Notes | Physical · Mobile · IoT · DDoS · Ransomware